

BCS2420 – Computer Security Final Exam

2025-03-21

Date/Time: 21-March-2025 / 12:00 – 14:00

Format: Closed-book exam

Allowed aids: Pens, simple (non-programmable) calculator

Instructions:

- The exam consists of 14 questions.
- Answer **all** questions in the space provided.
- Ensure your name and ID are on **every** page.
- No additional materials are required.
- **Good luck!**

Part A

1. Which statement about the STRIDE threat-modeling method is correct?

- (a) STRIDE focuses solely on DoS attacks and ignores other threat categories.
- (b) STRIDE stands for Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Escalation of Privilege and helps ensure common threats are not overlooked.
- (c) STRIDE is used only for cryptographic key management, not application-level threats.
- (d) STRIDE is an alternative to risk equations and cannot be combined with other modeling approaches.

2. Consider the risk equation ($R = T \times V \times C$). Which best describes V (vulnerability)?

- (a) The precise dollar amount of potential damage.
- (b) The attacker's level of motivation and skill.
- (c) The probability that the system, if attacked, will be successfully compromised.
- (d) The cost to remediate any discovered flaw.

3. Which adversary attribute most directly addresses their technical means and skill set?

- (a) Objectives
- (b) Funding Level
- (c) Methods
- (d) Capabilities

4. Which of the following correctly compares symmetric vs. public-key (asymmetric) cryptography?

- (a) Symmetric ciphers typically require significantly larger keys than public-key ciphers to achieve the same security level.

- (b) Public-key systems are always faster in bulk data encryption than symmetric systems.
- (c) Symmetric systems require a pre-shared secret for both encryption and decryption, while public-key systems use separate public and private keys.
- (d) Public-key cryptography is only used for direct content encryption, never for key exchange.

5. Which statement about stream ciphers is true?

- (a) They encrypt entire files as one large block, never bit by bit.
- (b) They produce a one-time pad of infinite length for all practical purposes.
- (c) They encrypt data one bit/character at a time, often combined with a keystream generator.
- (d) They always require random access to previous ciphertext blocks to decrypt.

6. In a typical digital signature workflow, why do we hash the message before signing?

- (a) To guarantee the public key is large enough.
- (b) To reduce the data length for faster signature operations and to detect any message alteration.
- (c) Because hashing ensures no collisions exist for any two distinct inputs.
- (d) Because signing the raw message is impossible without a one-time pad.

7. Which of the following is the best reason to include a random unique salt for each user's stored password hash?

- (a) It speeds up legitimate login attempts.
- (b) It guarantees that no offline attacks are possible.
- (c) It prevents the use of precomputed hash tables (rainbow tables) across multiple users.
- (d) It makes the hashing algorithm invertible for large datasets.

8. **Which step most effectively slows down offline password guessing attacks if an attacker has obtained the hashed password file?**
- (a) Applying a password policy that locks the account after three failed online attempts
 - (b) Using a specialized key-stretching algorithm with salts and high iteration counts
 - (c) Using only uppercase letters and digits in all stored passwords
 - (d) Changing the default TCP port for remote login to an uncommon number
9. **What is a fundamental difference between passive and active attackers during a network communication?**
- (a) A passive attacker only measures bandwidth usage, whereas an active attacker only disrupts hardware.
 - (b) A passive attacker attempts to observe traffic, whereas an active attacker may inject or modify data.
 - (c) A passive attacker always uses advanced cryptanalysis, while an active attacker focuses on social engineering.
 - (d) A passive attacker must first authenticate to the network, while an active attacker can remain anonymous.
10. **Which statement correctly applies to a firewall running a “default-allow” policy?**
- (a) It blocks all inbound and outbound traffic unless explicitly permitted.
 - (b) It allows traffic by default, creating a risk that unrecognized services remain accessible.
 - (c) It inspects application-layer data but never logs denied traffic.
 - (d) It automatically drops traffic on commonly used HTTP ports.
11. **A user visits a forum and inadvertently runs malicious scripts posted by another user’s comment. The malicious content is stored on the server and delivered to all who view that comment. Which term best describes this attack?**
- (a) Reflected cross-site scripting
 - (b) Stored cross-site scripting
 - (c) Cross-site request forgery
 - (d) DNS cache poisoning
12. **Which situation most clearly illustrates a man-in-the-middle attack?**
- (a) An attacker brute-forces a user’s password hash stored in a database dump.

- (b) An attacker intercepts key exchange messages and substitutes public keys, relaying data so both endpoints believe they communicate directly.
- (c) A user leaves their workstation unlocked, allowing a coworker to read confidential files.
- (d) A malicious script on a website reads cookies from a completely different domain.

Part B

1. Explain how a formal security policy helps guide threat modeling. Why can a policy violation lead to a system's non-secure state? Provide an example.
2. Define how online password guessing differs from offline password guessing. Identify one defense mechanism that specifically targets offline attacks and explain why it is ineffective against online attacks.
3. Summarize the key fields of an X.509 certificate that ensure the binding between a subject's name and public key. Why is the certificate's issuer signature essential to preventing impersonation?

Part C

1. Briefly outline how a Trojan horse differs from a worm in terms of user interaction requirements and typical propagation.
2. **An organization discovers a kernel-mode rootkit on a server.**
 - Describe how hooking or overwriting system calls helps a rootkit hide its files and processes.
 - Propose two steps to remove the rootkit and reduce the chance of reinfection.
3. A developer implements an Diffie-Hellman key exchange within a chat application but does not authenticate each party's public share. How could an attacker exploit this to impersonate users (man-in-the-middle)? Propose one countermeasure to preserve forward secrecy **and** ensure authenticity.

End of Exam